Dédale

Fiche de défense pour le jury

Secure Horizons, Track 2
10–11 octobre 2026

Orbis Pay est une entreprise fictive.

La menace défendue. Un salarié d'Orbis Pay et l'agent IA interne qui travaille pour lui. Le salarié peut cliquer un lien de phishing, coller un secret ou envoyer un fichier hors de l'entreprise. L'agent lit un mail piégé, prend la consigne cachée pour une tâche et tente d'appeler un outil sensible avec ses propres droits. Dédale suit les deux chemins jusqu'au même dossier SOC, où un humain décide.

Les contrôles

- Passerelle : tout appel d'outil de l'agent la traverse. Sur soupçon, l'appel est retenu avant exécution et attend l'analyste.
- Droits minimaux : l'agent reçoit un jeton limité aux droits de sa tâche. Un appel hors de ce jeton est bloqué et le jeton révoqué.
- Canaris : faux secrets et faux mails semés chez Orbis Pay. Un canari touché ouvre l'incident sans attendre le classement.
- Boîte noire : la chaîne entrée, consigne, outil, sortie et riposte est reconstruite ; le texte piégé est neutralisé avant stockage.
- Décision humaine et arrêt : « couper » arrête la session et révoque le jeton, « reprendre » libère l'appel retenu. Le poste du salarié est averti avant le geste, jamais bloqué.
- Exports : incident au format ECS, règles Sigma rejouables dans un SIEM, brouillon NIS2 qui rappelle les échéances.

Correspondances (repères, pas une certification)

OWASP Agentic ASI01, détournement d'objectif	consigne cachée d'un mail suivie par l'agent : signal de classement et canari
ASI02, usage abusif des outils	appel d'outil retenu par la passerelle avant exécution
ASI03, abus d'identité et de privilèges	jeton de tâche, droits accordés comparés aux droits nécessaires, révocation
MITRE ATLAS	AML.T0051.001 injection indirecte par un document lu ; AML.T0053 invocation d'outil par l'agent ; AML.T0057 fuite de données
MITRE ATT&CK	T1566 phishing (scène salarié). T1552, T1048, T1567 et T1200 sont typés pour les gestes du poste, sans mesure du banc
NIST CSF 2.0	Détecter : DE.CM-09, DE.AE-02, DE.AE-08. Répondre : RS.MA-02, RS.AN-03, RS.MI-01
NIS2, article 23	alerte précoce sous 24 h : Dédale prépare le brouillon, l'humain qualifie l'incident et notifie

Limites

Scénarios et entreprise fictifs. Trafic synthétique produit par notre propre banc ; le cerveau de l'agent est scripté. Aucune intégration native : pas de capteur sur le Mac, pas d'Outlook ni de Gmail, pas d'annuaire d'identités. Aucune validation réglementaire : le brouillon NIS2 n'est ni qualifié ni envoyé, et les correspondances ci-dessus n'ont été auditées par personne.

Ce que le banc a mesuré le 10 octobre

Chaque campagne tourne contre un backend lancé pour elle, sur un port libre, avec une base SQLite temporaire. Le bilan ne compte que les sessions de la campagne ; un taux a pour dénominateur les sessions émises. Rapports complets dans `attaque/rapports/`.

Campagne `c1010184730f49a`, le banc poste au vrai backend 100 sessions, 25 par type :

- humain et script : 0/50 classées agent IA, 0/50 incident ouvert ; 50/50 reçoivent leur classe exacte ;
- agent IA externe : 25/25 classées agent IA, 25/25 incidents ;
- agent interne synthétisé par le banc : 0/25 classées agent IA, les 25 restent « inconnu ». Le canari ouvre pourtant 25/25 incidents et suspend 25/25 sessions. Au sens strict, la détection vaut donc 25/50 ;
- le classement tombe au 5e événement, médiane 3,5 s en horloge simulée. L'incident existe déjà dans la réponse au POST : médiane 0,32 ms sur 50 incidents.

Campagne `c10101848586937`, 25 sessions jouées par la vraie bibliothèque `interne/` et sa passerelle : 25/25 classées agent IA, 25/25 incidents, 25/25 sessions suspendues, aucun rapport envoyé (0/25). Classement en 6 ms médian (horloge réelle), incident ouvert 1,24 ms médian après l'événement déclencheur.

Non mesuré : le délai de décision et de confinement (aucun analyste dans la boucle), un agent externe contre le vrai `leurres/` (le simulateur du banc ne suit pas encore ses pièges), un modèle réel.

Tests

173 tests réussis : backend 45, interne 35, leurres 19, poste 17, attaque 23 (pytest) et 34 tests des scripts de démo (unittest). Ils vérifient le prototype, pas une détection en production.

Rejouer une campagne :

```
cd attaque && uv run python campagne.py \
--mode autonome --n 25 --backend <url>
```

Parcours de démo : `docs/DEMO.md`.

Source : `docs/FICHE_JURY.md`, rapports `attaque/rapports/campagne-c1010184730f49a.md` et `campagne-c10101848586937.md`, suites de tests du dépôt. Orbis Pay et ses données sont fictifs.